COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

# Security+ 2.5 · Hardening Techniques

Mestre CyberSec · **Aula 2.5 — Hardening Techniques** (12:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

**Resumo Executivo da Aula:** Hardening = reduzir superfície de ataque ao mínimo: fechar portas desnecessárias, remover serviço/software (bloatware), trocar senha default, desabilitar conta não usada, patch, MFA, app allowlist, disable USB autorun, BIOS/UEFI password, disable USB boot.

## 💡 Highlights que a prova CompTIA cobra

- Surface de ataque = tudo que podes ser atacado — MINIMIZE
- CIS benchmarks = o checklist de hardening por plataforma (padrão da indústria)
- NÃO usar a conta default; desabilitar porta/serviço não usado

## 🎯 Dicas de Prova & Cenários Típicos da Banca

- 'reduces the attack surface of a system' = hardening
- 'checklist of security configuration per platform' = CIS benchmark

## 🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.5 — Hardening Techniques)

**Por que este aprofundamento é cobrado na prova?:** O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

**• Hardening (Endurecimento) (N/A)**
O processo de reduzir a superfície de ataque de um sistema aplicando configurações seguras, removendo componentes desnecessários e aplicando políticas de segurança rígidas.
⚠️ ***Armadilha CompTIA:*** *Any answer that 'reduces the attack surface of a system' or 'secures a default configuration' = hardening. Watch for this keyword on SY0-701 Objective 1.3.*

**• Superfície de Ataque (N/A)**
A soma de todos os pontos (portas, serviços, código, usuários, interfaces) onde um usuário não autorizado pode tentar entrar ou extrair dados de um sistema.
⚠️ ***Armadilha CompTIA:*** *If the question asks 'what is being minimized?', the answer is the attack surface. Hardening = minimizing the attack surface.*

**• CIS Benchmarks (Benchmarks do Center for Internet Security)**
Listas de verificação padrão da indústria, baseadas em consenso, para configuração segura de tecnologias, desenvolvidas pelo Center for Internet Security; usadas como linha base para hardening.
⚠️ ***Armadilha CompTIA:*** *Trigger phrase: 'industry-recognized checklist of security configuration per platform' or 'configuration baseline' = CIS Benchmarks. Don't confuse with NIST frameworks — CIS is the configuration guide.*

**• Credenciais Padrão / Conta Padrão (N/A)**
Nomes de usuário e senhas pré-configurados que acompanham um sistema (ex.: admin/admin, root). Devem ser alterados ou desativados durante o hardening, pois são publicamente conhecidos.
⚠️ ***Armadilha CompTIA:*** *Any question showing a known vendor default login being exploited = hardening failure. Both default credentials AND default accounts must be removed/renamed.*

**• Bloatware (Software Inchado) (N/A)**
Software pré-instalado desnecessário que acompanha um dispositivo, aumenta a superfície de ataque e deve ser removido durante o hardening.
⚠️ ***Armadilha CompTIA:*** *If a question asks 'what should be uninstalled to reduce the attack surface on a new laptop?' = Bloatware. Less software = smaller attack surface.*

**• Lista de Aplicativos Permitidos (Whitelist) (N/A)**

Controle de hardening que permite que SOMENTE aplicativos aprovados sejam executados no sistema, bloqueando todo o resto por padrão — o inverso de uma block list/blacklist.

⚠️ ***Armadilha CompTIA:*** *Allow list = deny by default (more secure). Block list = allow by default (weaker). On exams, prefer allow list for high-security environments. Distinguish from block list.*

**• Patching (Aplicação de Patches) (N/A)**

Processo de aplicar atualizações do fabricante para corrigir vulnerabilidades, bugs ou melhorar funcionalidades; atividade central de hardening para sanear exploits conhecidos.

⚠️ ***Armadilha CompTIA:*** *Question showing an unpatched CVE being exploited = patch management failure. Patching is mandatory hardening; pair with firmware/OS updates for full coverage.*

**• Autorun USB (Desabilitar) (N/A)**

Recurso do sistema que executa automaticamente software em um dispositivo USB conectado. Desabilitar o autorun é um controle de hardening para impedir a execução de código malicioso por mídia removível.

⚠️ ***Armadilha CompTIA:*** *Scenario: 'malware spreads by inserting a USB drive' = USB autorun was enabled. Also disable boot from USB in BIOS/UEFI to complete the hardening.*

## 🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

### 📌 Redução da Superfície de Ataque e Desativação de Portas/Serviços

🏠 **Analogia Intuitiva:** Uma casa com 20 janelas de vidro, 6 portas externas e um alçapão no telhado é muito mais difícil de defender contra ladrões do que uma casa com apenas uma porta blindada e nenhuma janela acessível da rua. O hardening de um servidor é como murar as 19 janelas desnecessárias, trancar o alçapão e manter apenas a única porta necessária para o negócio. Se você não usa Telnet (porta 23) ou FTP (porta 21), desligue o serviço; uma porta fechada não pode ser invadida.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais de fábrica vêm com inúmeros serviços auxiliares ativados para facilitar a compatibilidade com usuários domésticos. Cada serviço ativo roda código que pode conter bugs, vulnerabilidades de estouro de buffer (buffer overflow) ou falhas de injeção exploráveis.

🛡️ **Visão do Auditor de GRC:** Executar varreduras periódicas com scanners de vulnerabilidade (Nessus/Nmap) para auditar portas abertas; validar que apenas os serviços constantes na Matriz de Portas Autorizadas do plano diretor de segurança estejam em execução.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'system administrator disables unused network services and closes unnecessary ports to minimize potential entry points'. Resposta: Attack Surface Reduction / Hardening.

### 📌 CIS Benchmarks e Linhas de Base de Segurança (Security Baselines)

🏠 **Analogia Intuitiva:** É como a cartilha de vigilância sanitária ou as normas técnicas da ABNT/ISO para a cozinha de um grande hospital: não é uma questão de opinião do cozinheiro, é um checklist oficial de 300 itens minuciosos (temperatura exata do freezer, espessura da tábua de corte, tempo de lavagem das mãos) testado exaustivamente por especialistas para evitar que pacientes adoeçam. O CIS Benchmark é esse checklist de excelência técnica para configurar Windows, Linux, AWS ou Cisco de forma impenetrável.

🔍 **Causa Raiz / Por que foi criado:** Administradores configurando sistemas manualmente cometem erros humanos, adotam atalhos inseguros e geram inconsistências entre máquinas. Guias padronizados eliminam desvios de configuração (drift) e garantem proteção uniforme.

🛡️ **Visão do Auditor de GRC:** Fiscalizar o uso de ferramentas de conformidade automatizada (SCAP / OpenSCAP) que comparam as configurações dos servidores contra os perfis Level 1 e Level 2 do Center for Internet Security (CIS); exigir aprovação formal de exceções de risco para qualquer item não atendido.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'industry-recognized, consensus-based best practice configuration guidelines used worldwide to harden operating systems, applications, and cloud environments'. Resposta: CIS Benchmarks.

### 📌 Princípio do Menor Privilégio (Principle of Least Privilege - PoLP)

🏠 **Analogia Intuitiva:** Em um grande navio de cruzeiro, o passageiro tem um cartão magnético que só abre a porta da sua própria cabine. O mecânico do navio tem um cartão que abre a sala de máquinas, mas não abre a recepção nem o cofre do capitão. Ninguém anda pelo navio com a chave mestra de tudo o tempo todo. Se um passageiro perder seu cartão no convés, o ladrão só consegue entrar em uma cabine e não tem como afundar o navio.

🔍 **Causa Raiz / Por que foi criado:** Conceder privilégios administrativos para usuários comuns simplifica o suporte técnico (softwares não reclamam de permissão), mas se o usuário for vítima de phishing ou baixar um malware, o código malicioso executará com os mesmos privilégios do usuário e dominará a máquina inteira.

🛡️ **Visão do Auditor de GRC:** Realizar revisões periódicas de acesso (Access Reviews); proibir contas de usuários comuns no grupo de Administradores Locais; exigir que administradores de sistemas utilizem contas separadas e dedicadas para tarefas administrativas com PAM (Privileged Access Management).

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'users and processes are granted only the minimum permissions necessary to perform their required job duties'. Resposta: Principle of Least Privilege (PoLP).

### 📌 Desativação e Renomeação de Contas Padrão (Default Accounts & Passwords)

🏠 **Analogia Intuitiva:** Comprar um roteador Wi-Fi ou câmera de segurança e deixar o usuário como 'admin' e a senha como 'admin' ou '123456' é como comprar uma casa nova e deixar na porta da frente a chave de plástico amarela que a construtora usou na obra com um bilhete: 'Porta aberta para quem quiser entrar!'. Todo ladrão na rua conhece a senha de fábrica de todos os aparelhos do mercado.

🔍 **Causa Raiz / Por que foi criado:** Fabricantes programam credenciais padrão idênticas de fábrica para permitir o primeiro acesso pelo técnico. Botnets automatizadas (como a Mirai) varrem a internet inteira 24 horas por dia testando essas listas de senhas padrão em dispositivos recém-ligados.

🛡️ **Visão do Auditor de GRC:** Estabelecer procedimento operacional padrão (SOP) de comissionamento de ativos exigindo a troca imediata de senhas padrão, renomeação de contas como 'Administrator' e desativação da conta 'Guest' antes de qualquer conexão à rede de produção.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'first step a network administrator must perform when deploying a new network appliance, router, or server'. Resposta: Change default passwords / Disable default accounts.

## ⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

| Cenário Típico de Exame / Situação Prática | Conceito Técnico & Resposta da Banca |
|---|---|
| Desativar portas de rede e serviços desnecessários para fechar portas de entrada a invasores | **Redução da Superfície de Ataque (Attack Surface Reduction)** |
| Guias consensuais da indústria internacional para endurecer sistemas operacionais e servidores | **CIS Benchmarks** |
| Garantir que colaboradores e processos tenham somente as permissões mínimas essenciais para seu trabalho | **Princípio do Menor Privilégio (Principle of Least Privilege)** |
| Ação inicial obrigatória na instalação de qualquer novo roteador, switch ou dispositivo IoT corporativo | **Alteração de Credenciais Padrão (Change Default Passwords)** |
| Substituição de protocolos em texto claro (Telnet, HTTP) por versões criptografadas seguras (SSH, HTTPS) | **Endurecimento de Protocolos (Protocol Hardening - SSH/HTTPS)** |
| Conta de sistema operacional padrão que deve ser mantida desativada por política de segurança | **Conta de Convidado (Guest Account)** |

## ✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

**QUESTÃO 1 · CENÁRIO DE EXAME**

**Uma empresa está preparando uma imagem hardening do Windows 11 para o departamento financeiro. A imagem atual inclui jogos, softwares de avaliação e utilitários de fornecedores que os funcionários do financeiro não usam. A equipe de segurança quer reduzir a superfície de ataque antes da implantação. Qual ação de hardening a equipe deve tomar?**

**A)** Habilitar AutoRun para mídias removíveis para que os usuários instalem ferramentas necessárias.

**B)** Conceder direitos de administrador local aos usuários do financeiro para gerenciar o software extra.

**C)** Remover aplicativos e serviços pré-instalados desnecessários da imagem.

**D)** Desativar o firewall do Windows na imagem para evitar conflitos de aplicativos.

**QUESTÃO 2 · CENÁRIO DE EXAME**

**Um técnico instala uma nova impressora multifuncional de rede na LAN corporativa. Durante uma revisão de segurança, o console web da impressora ainda está acessível com as credenciais administrativas padrão do fornecedor. Qual etapa de hardening é mais apropriada?**

**A)** Mover a impressora para uma rede sem fio de convidados e manter as credenciais padrão.

**B)** Alterar as credenciais administrativas padrão e desativar contas de gerenciamento não utilizadas.

**C)** Desativar o gerenciamento HTTPS e usar Telnet para acesso administrativo.

**D)** Habilitar SNMPv1 com a community string public para facilitar o monitoramento.

**QUESTÃO 3 · CENÁRIO DE EXAME**

**Um analista de segurança revisa um servidor de arquivos legado e descobre que a conta interna Guest está habilitada, a conta interna Administrator ainda usa seu nome original e uma conta de um administrador que saiu da empresa permanece ativa. Qual ação de hardening aborda melhor essas descobertas?**

**A)** Definir todas as contas afetadas para usar senhas que nunca expiram.

**B)** Adicionar as contas a um grupo privilegiado de monitoramento para auditoria.

**C)** Habilitar acesso via área de trabalho remota para as contas para simplificar a administração.

**D)** Desativar ou renomear contas padrão desnecessárias e desativar contas inativas.

**QUESTÃO 4 · CENÁRIO DE EXAME**

**Uma verificação de vulnerabilidades encontra uma CVE crítica em um servidor web público porque um patch necessário do sistema operacional nunca foi aplicado. Qual técnica de hardening aborda diretamente essa descoberta?**

**A)** Aplicar os patches ausentes do sistema operacional e dos aplicativos.

**B)** Implementar uma application allow list no servidor web.

**C)** Desativar o AutoRun de USB nas estações de trabalho dos administradores.

**D)** Configurar uma senha de BIOS/UEFI no servidor.

**QUESTÃO 5 · CENÁRIO DE EXAME**

**Um usuário baixa um executável malicioso da internet e o executa em uma estação de trabalho gerenciada, infectando o sistema. A equipe de segurança quer impedir que executáveis não aprovados sejam executados, mesmo que sejam baixados. Qual ação de hardening deve ser implementada?**

**A)** Desativar o AutoRun de USB em todos os endpoints.

**B)** Exigir que os usuários executem como administradores locais.

**C)** Configurar uma application allow list que permita apenas executáveis aprovados.

**D)** Mover a pasta Downloads do usuário para uma unidade de rede mapeada.

**QUESTÃO 6 · CENÁRIO DE EXAME**

**Um contratado conecta uma unidade USB a uma estação de trabalho corporativa. O malware na unidade é executado automaticamente porque o Windows processa um arquivo autorun.inf. Qual ação de hardening deve ser aplicada para evitar esse comportamento?**

**A)** Habilitar BitLocker To Go para todos os dispositivos USB.

**B)** Configurar MFA para todos os logins de usuários.

**C)** Instalar uma application allow list apenas nos servidores.

**D)** Desativar AutoRun/AutoPlay para mídias removíveis por meio de Política de Grupo.

**QUESTÃO 7 · CENÁRIO DE EXAME**

**Uma empresa está preocupada com roubo de laptops e com atacantes que podem ter acesso físico breve. Eles querem evitar que alguém inicialize a partir de uma unidade USB externa e contorne os controles do sistema operacional. Qual ação de hardening é mais eficaz?**

**A)** Definir uma senha de BIOS/UEFI e desativar a inicialização a partir de dispositivos externos.

**B)** Habilitar AutoRun para dispositivos USB e exigir senhas complexas.

**C)** Instalar uma application allow list no sistema operacional.

**D)** Aplicar os patches mais recentes do sistema operacional e habilitar MFA.

**QUESTÃO 8 · CENÁRIO DE EXAME**

**O portal VPN da empresa autentica usuários apenas com nome de usuário e senha. Após uma campanha de credential stuffing, várias contas válidas foram acessadas. Qual ação de hardening mitiga melhor esse risco?**

**A)** Desativar contas VPN não utilizadas e aplicar patches no appliance VPN.

**B)** Exigir autenticação multifator para acesso VPN.

**C)** Implementar uma application allow list nos clientes VPN.

**D)** Configurar senhas de BIOS/UEFI nos laptops remotos.

**QUESTÃO 9 · CENÁRIO DE EXAME**

**Um servidor Linux interno executa FTP, Telnet e SMB, mas nenhum desses serviços é necessário para a função do servidor. Qual ação de hardening reduz melhor a superfície de ataque?**

**A)** Instalar um firewall baseado em host e deixar os serviços em execução.

**B)** Habilitar MFA para logins locais e manter FTP/Telnet ativos.

**C)** Parar e desativar serviços desnecessários, depois fechar as portas associadas.

**D)** Mover o servidor para uma VLAN diferente sem alterar os serviços.

**QUESTÃO 10 · CENÁRIO DE EXAME**

**Uma organização quer padronizar configurações seguras para seus servidores Windows e precisa de um conjunto reconhecido de benchmarks de hardening. Qual recurso deve ser usado como base?**

**A)** CIS Benchmarks.

**B)** OWASP Top 10.

**C)** NIST SP 800-63.

**D)** PCI DSS.

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

**Questão 1: Alternativa C — Remover aplicativos e serviços pré-instalados desnecessários da imagem.**
Remover bloatware e aplicativos/serviços pré-instalados desnecessários reduz a superfície de ataque, pois elimina código que pode conter vulnerabilidades ou ser explorado. Habilitar AutoRun, conceder direitos de administrador local e desativar o firewall aumentam o risco em vez de fortalecer o sistema.

**Questão 2: Alternativa B — Alterar as credenciais administrativas padrão e desativar contas de gerenciamento não utilizadas.**
Credenciais padrão são uma fraqueza conhecida e devem ser alteradas antes de o dispositivo entrar em produção. Desativar contas de gerenciamento não utilizadas também reduz a superfície de ataque. Manter padrões, usar Telnet ou habilitar SNMPv1 com public aumenta a exposição.

**Questão 3: Alternativa D — Desativar ou renomear contas padrão desnecessárias e desativar contas inativas.**
Contas padrão e inativas são pontos de entrada comuns. O servidor deve ter contas padrão desnecessárias desativadas ou renomeadas e contas inativas desativadas ou removidas. Senhas que nunca expiram, privilégios adicionados e acesso remoto aumentam o risco.

**Questão 4: Alternativa A — Aplicar os patches ausentes do sistema operacional e dos aplicativos.**
A aplicação de patches corrige vulnerabilidades conhecidas em sistemas operacionais e aplicativos e é uma técnica central de hardening. Allow list, desativação de AutoRun de USB e senha de BIOS/UEFI são controles úteis, mas não corrigem diretamente o patch ausente.

**Questão 5: Alternativa C — Configurar uma application allow list que permita apenas executáveis aprovados.**
Uma application allow list impede a execução de executáveis não autorizados ou maliciosos, mesmo que tenham sido baixados. Desativar AutoRun ajuda com mídias removíveis, mas não com downloads. Direitos de administrador local aumentam o risco; mover a pasta Downloads não impede a execução.

**Questão 6: Alternativa D — Desativar AutoRun/AutoPlay para mídias removíveis por meio de Política de Grupo.**
Desativar AutoRun/AutoPlay para mídias removíveis impede que arquivos autorun.inf maliciosos em unidades USB sejam executados automaticamente. BitLocker protege dados em repouso, MFA protege autenticação, e allow list apenas em servidores não impede autorun em estações de trabalho.

**Questão 7: Alternativa A — Definir uma senha de BIOS/UEFI e desativar a inicialização a partir de dispositivos externos.**
Uma senha de BIOS/UEFI e a desativação de opções de boot externo impedem que um atacante com acesso físico altere a ordem de boot ou inicialize outro sistema operacional a partir de mídia removível. Controles em nível de SO podem ser contornados se o atacante inicializar externamente.

**Questão 8: Alternativa B — Exigir autenticação multifator para acesso VPN.**
MFA adiciona um segundo fator além de uma senha comprometida, mitigando diretamente credential stuffing e reuso de senhas. As outras ações são medidas de hardening, mas não tratam da autenticação de fator único.

**Questão 9: Alternativa C — Parar e desativar serviços desnecessários, depois fechar as portas associadas.**
A ação de hardening mais forte é remover ou desativar serviços desnecessários e fechar as portas associadas, reduzindo a superfície de ataque. Firewall, MFA ou segmentação por VLAN podem ajudar, mas não eliminam os serviços vulneráveis.

**Questão 10: Alternativa A — CIS Benchmarks.**
CIS Benchmarks fornecem diretrizes de configuração segura baseadas em consenso para sistemas operacionais, servidores e aplicativos. OWASP Top 10 trata de riscos de aplicações web, NIST SP 800-63 cobre identidade digital, e PCI DSS é um padrão da indústria de cartões de pagamento.